SBOM for Operational Compliance - SPDX Operations Profile

Ummo Schwarting
Co-Initiator SPDX Operations Profile
Open Source Compliance Expert at Deloitte.

SPDX Introduction

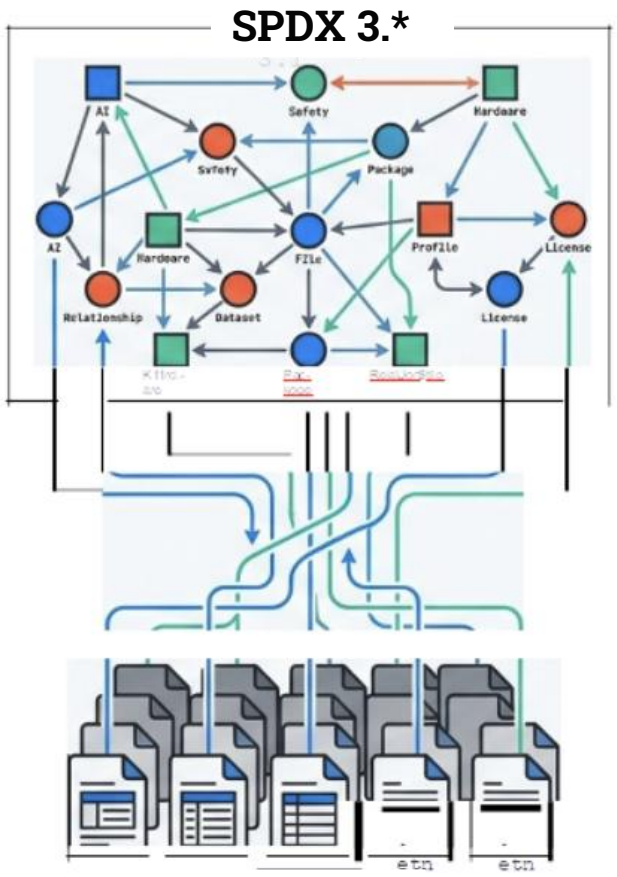
https://spdx.github.io/spdx-spec/

SPDX is an open standard for communicating Software Bill of Material (SBOM) information. SPDX reduces redundant work by providing common formats for organizations and communities to share important data.

- The SPDX specification is recognized as ISO/IEC 5962:2021
- SPDX is an Open Source project hosted by the Linux Foundation

SPDX 3 expands the standard beyond describing metadata on software for products: The format now supports a knowledge graph which allows tailored data modeling for specific use cases based on profiles.

For more details, see the FOSDEM 2026 talk: "What is new in SPDX 3.1?"



SPDX

Expanding SBOMs

The Current State & Emerging Needs

Moving beyond traditional SBOMs to meet a new wave of regulatory and operational demands.

The Challenge: Expanding Requirements

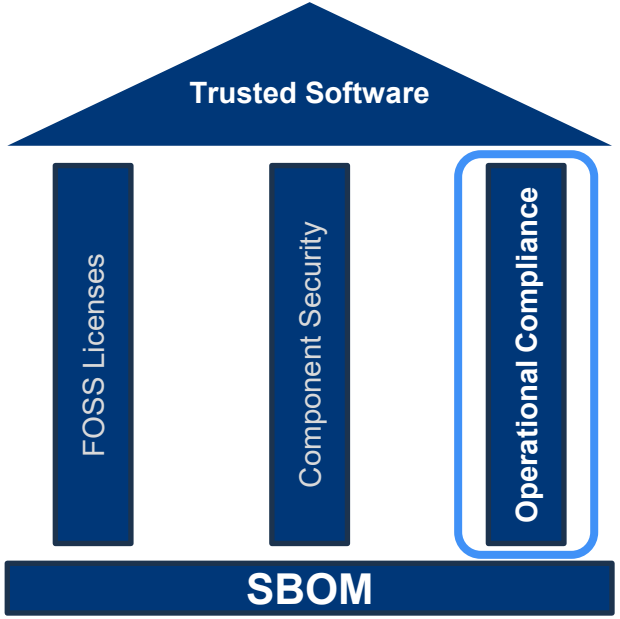
Growing regulatory demands require a much broader view of operational compliance.
This information isn't necessarily part of the distributed supply chain data and is often siloed within an organization.

The Opportunity: SBOMs are Established

Software Bills of Materials (SBOMs), using formats like SPDX, are an established standard for managing licensing compliance data and mapping to security status information across the software supply chain.

The Objective: A Paradigm Shift

Extending the scope of SBOMs to capture the crucial data needed "inside" an organization for process compliance and audit-readiness.



SPDX

SPDX 3: A Data Model, Not Just a Format

A Match for Operational Data

SPDX 3.0 fundamentally rethinks how we represent software data, evolving from static documents into a living knowledge graph.

This data modeling approach provides the critical ability to enrich software artifacts with internal operational data, designed to remain within your organization, while benefiting from the overarching standardized format.

The New SBOM:

A foundational data model allows us to extend SBOMs far beyond their original scope, enabling a living, queryable knowledge graph for all software metadata.

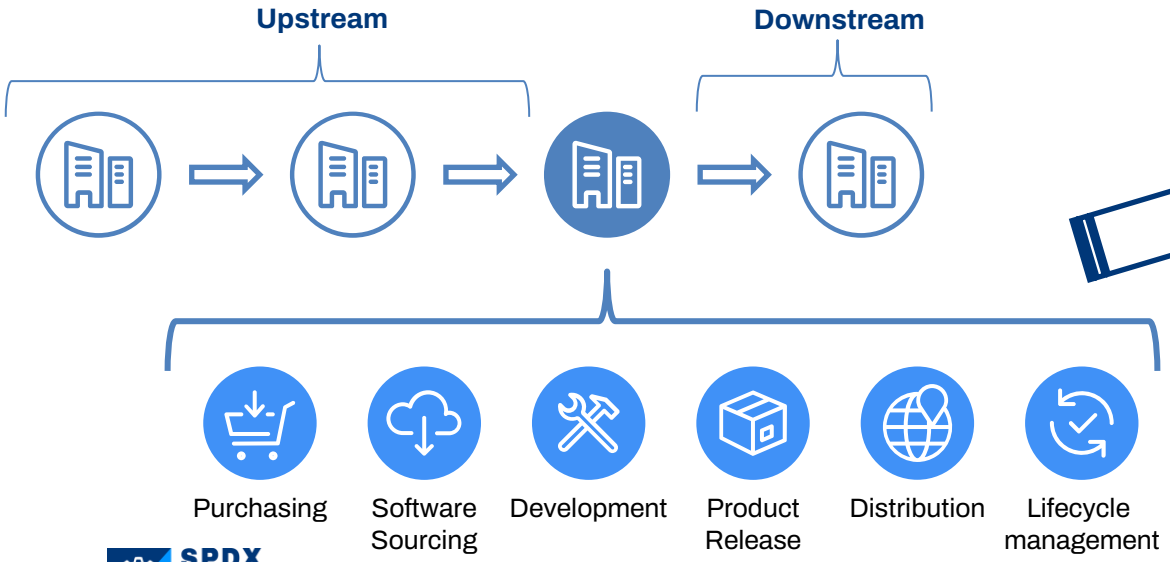
Operational Compliance requires business context attribution for:

- Internal governance
- Regulatory requirements
- Audit-readiness
- Attestations of assessments
- …

SPDX

The SPDX 3 Operations Profile

Modeling the ‚inside‘



SPDX OPERATIONS

See also https://github.com/spdx/spdx-3-model/tree/develop/model/Operations/

- Connections between External and Internal Data
- Export Control Assessment
- (Open Source) Project Information
- Distribution Context

Data classes

- Assesment
- Project

SPDX

Seamless Integration & Efficiency

Leveraging existing infrastructure

Standardized Connection

The SPDX 3 data model provides a standard way to connect disparate operational data from various tools directly to software artifacts.

Efficiency Gains

Leverage existing infrastructure and tools. There is no need for costly replacement projects; work with the systems you already have in place.

Best of Both Worlds

Combines the classic SBOM advantage (data close to artifacts) with the flexibility of a data model for powerful internal use cases and reporting.

Data Segregation & Protection

The profile frame allows separating sensitive internal operational data from public-facing SBOM information. Confidentiality is controlled while still allowing comprehensive internal compliance.

Outlook & Call to Action

Join us – We are looking for your input and your use cases!

SPDX OPERATIONS

Weekly meeting: on Fridays at 10:00 ET
Mailing list: https://lists.spdx.org/g/spdx-operations

Why join?
- Contribute to the data model and learn about interaction with other profiles

OPENCHAIN

There will be an Operational Compliance Study Group in OpenChain.
In Open Chain we want to focus on the topic and approach in general, where SPDX focuses on the “how”.

Why join?
- Contribute your ideas and requirements to best practices
- Network with peers on Operational Compliance

SPDX

Website:
https://spdx.dev/

Github:
https://github.com/spdx/

SPDX Slack:
https://spdx.slack.com/

Thank You!

Any Questions?

SPDX OPERATIONS Profile Leads

Ummo Schwarting

Deloitte.

Marcel Kurzmann

BOSCH

Matthew Crawford

arm